REAL-TIME DEVSECOPS KUBERNETES

Order Management Production Project

1. Workflow

GitHub PR → tests → SAST → dependency scan → Gitleaks → Docker → Trivy → SBOM → Cosign → ACR → GitOps → Argo CD → AKS → Kyverno → monitoring.

2. Local setup

cp .env.example .env; docker compose build; docker compose up -d; open http://localhost:3000.

3. Security

Semgrep for source, pip-audit/npm audit for dependencies, Gitleaks for secrets, Trivy for images/config, Syft for SBOM, Cosign for signing.

4. Azure

Terraform provisions RG, VNet, AKS, ACR, Key Vault and Log Analytics. AKS uses Workload Identity and ACR pull role.

5. Kubernetes

Deployments use non-root security contexts, probes, resource limits, RBAC, NetworkPolicies, HPA, PDB and anti-affinity.

6. GitOps

CI updates immutable image references in the GitOps repo. Argo CD reconciles Git to AKS with automated sync/self-healing for non-production.

7. Policy

Kyverno enforces non-root containers, resources and non-latest production images. Add signed-image verification and approved-registry policies to production.

8. Monitoring

Prometheus/Grafana and Azure Monitor provide metrics. Loki can centralize JSON application logs.

9. Recovery

Use PostgreSQL backups, Git revert, immutable image digests and kubectl/Helm rollback procedures. Test restore regularly.

10. Interview

40 project-specific interview questions are provided in docs/INTERVIEW-QUESTIONS.md.